Defensive Security Operations

SOC Foundations, Incident Response, Digital Forensics, and Log Analysis

Defensive Security focuses on protecting organizational assets through the dual tasks of prevention and detection. This module provides a comprehensive overview of the **Security Operations Center (SOC)**, structured around the three pillars of **People, Process, and Technology**.

We explore the methodologies of **Incident Response (IR)** using the **SANS (PICERL)** and **NIST** frameworks to manage the lifecycle of a breach. Furthermore, the content delves into **Digital Forensics**, detailing evidence acquisition and the analysis of volatile vs. non-volatile data.

Finally, we examine **Log Analysis** as the primary means of tracing digital footprints, utilizing Windows Event IDs and Linux command-line tools to identify and mitigate malicious activity within a network.

This **documentation** and **learning** approach is strongly inspired by the structured, hands-on content provided by **TryHackMe**, which significantly contributed to practical understanding of "Defensive Security" operations.

DOCUMENTED BY

Kaustubh Ghosalkar aka "WEIRDO"

LINKEDIN GITHUB

WEIRDO

1. The Defensive Security Landscape

Defensive Security (handled by **Blue Teams**) aims to prevent intrusions and respond to those that occur. Core tasks include:

- **Asset Management:** Identifying and documenting all protected devices.
- **Preventative Measures:** Setting up **Firewalls** (traffic control) and **IPS** (Intrusion Prevention Systems) to block known attack signatures.
- **System Maintenance:** Constant updating and patching of vulnerabilities.
- **Security Awareness:** Training users to recognize threats like phishing.

2. Security Operations Center (SOC) Fundamentals

A SOC is a 24/7 facility dedicated to monitoring and defending an organization's infrastructure.

The Three Pillars of a Mature SOC

Pillar	Description
People	The SOC Team (Analysts, Engineers, Managers).
Process	Standardized methods like **Alert Triage** and reporting.
Technology	Tools like **SIEM**, **EDR**, and Firewalls.

The SOC Team Hierarchy

- **Level 1 Analyst:** First responders who perform **Alert Triage** and basic reporting.
- **Level 2 Analyst:** Deep-dive investigators who correlate data from multiple sources.
- **Level 3 Analyst:** Experienced hunters who handle critical incidents and threat indicators.
- **Security/Detection Engineer:** Build the logic and maintain the tools.

Alert Triage: The 5 Ws

1. **What?** The activity that triggered the alert (e.g., Port Scan).
2. **When?** Exact timestamp of the event.
3. **Where?** The destination host IP or directory.
4. **Who?** The source host name or user account involved.
5. **Why?** The reason for the activity (Malicious vs. Intended).

WEIRDO

3. Incident Response (IR) Methodology

An **Incident** is a **True Positive** alert representing a security breach, malware infection, or DoS attack.

IR Framework Comparison

SANS (PICERL)	NIST	Key Activity
Preparation	Preparation	Training teams and deploying tools.
Identification	Detection & Analysis	Determining if an event is an actual incident.
Containment	Containment/Eradication	Isolating affected systems to stop the spread.
Eradication	/Recovery	Removing the threat (malware) from the system.
Recovery		Restoring systems from backups.
Lessons Learned	Post-Incident Activity	Documenting gaps and preventing future occurrence.

4. Digital Forensics and Evidence Acquisition

Digital Forensics applies scientific investigation to digital devices to establish facts for legal or security purposes.

Forensics Process

1. **Collection:** Identifying and securely acquiring devices (PC, Mobile, USB).
2. **Examination:** Filtering massive datasets to extract data of interest.
3. **Analysis:** Correlating evidence to draw a chronological conclusion.
4. **Reporting:** Presenting finding to law enforcement or management.

Evidence Acquisition Tools

- **Write Blockers:** Hardware/software used to prevent any data modification on the source drive during collection.
- **Chain of Custody:** A formal document tracking who handled the evidence, when, and where.

Windows Forensics: Memory vs. Disk

Type	Data Content	Tool Example
Disk Image	Files, OS logs, browser history (Non-volatile).	**FTK Imager**, **Autopsy**
Memory Image	Running processes, network connections (Volatile).	**DumpIt**, **Volatility**

WEIRDO

5. Log Fundamentals and Analysis

Logs are digital footprints. In defensive security, they are categorized to make investigation efficient.

Common Log Categories

- **Security Logs:** Authentication and authorization events.
- **System Logs:** OS startup, driver issues, and hardware events.
- **Application Logs:** Errors and updates specific to a software program.
- **Access Logs:** Web server requests (IP, Timestamp, URL).

Windows Event ID Reference

Event ID	Description
4624	Successful Login
4625	Failed Login
4720	User Account Created
4724	Password Reset Attempt

Command Section: Linux Log Analysis

Command	Usage Example	Purpose
cat	cat access.log	Displays the entire log content.
grep	grep "10.0.0.1" access.log	Searches for a specific IP or pattern.
less	less access.log	Views logs page-by-page (use / to search).

WEIRDO

6. Practical Tasks: Defensive Simulations

SOC and SIEM Simulation

- **Work Done: I practiced** navigating a SIEM dashboard to investigate unauthorized connection alerts.
- **Solution: I researched** unknown IP addresses and **found** that a port scan was initiated by a vulnerability scanner. **I solved** the triage by identifying the activity as "Intended" based on team notifications.
- **Result: I founded** the flag THM{000_INTRO_TO_SOC} after closing the alert.

Digital Forensics: The Ransomware Letter

- **Work Done: I researched** a ransom letter sent in PDF format to find the attacker's identity.
- **Solution: I practiced** using the command pdfinfo ransom-letter.pdf and **found** the author's name was **Ann Gree Shepherd**. To locate the kidnappers, **I solved** the EXIF data challenge by running exiftool image.jpg.
- **Result: I founded** the location (Milk Street) and the camera model (Canon EOS R6) used by the suspect.

Incident Response: Phishing Investigation

- **Work Done: I practiced** responding to a malware infection triggered by a phishing email.
- **Solution: I researched** the email sender and **found** the threat vector was an email attachment from **Jeff Johnson**. **I solved** the scoping task by identifying that 3 devices downloaded the file, but only 1 executed it.
- **Result: I founded** the flag THM{My_First_Incident_Response}.

Log Analysis: Windows Breach

- **Work Done: I researched** Windows Security logs to identify how an attacker compromised a system.
- **Solution: I practiced** filtering for Event ID **4720** and **found** a new user account named **hacked** was created by the **Administrator**. **I solved** the timeline by finding that the account was enabled on **6/7/2024**.
- **Result: I practiced** deep log analysis and **found** that a password reset had also occurred on the malicious account.

WEIRDO

Conclusion and Cheatsheet

Conclusion

Defensive security is a multi-layered discipline requiring a synergy between skilled personnel, rigid processes, and advanced technology. By utilizing **SIEM** for detection and following **SANS/NIST** playbooks for response, a SOC can minimize the impact of an attack. Understanding the nuances of **Digital Forensics** and **Log Analysis** ensures that every incident leaves a trail that can be reconstructed to prevent future breaches.

Fast Revision Cheatsheet

- **SOC Pillar:** People, Process, Technology.
- **SANS PICERL:** Prep, Identify, Contain, Eradicate, Recover, Lessons Learned.
- **Event ID 4624:** The most important ID for tracking successful logins.
- **Write Blocker:** Crucial for preserving evidence integrity.
- **Volatile Data:** RAM contents (lost on reboot); take Memory Image first!
- **Grep:** The "go-to" tool for searching patterns in large log files.
- **EXIF Data:** Metadata in images that often contains GPS and camera details.

WEIRD